

LAPORAN AUDIT KEAMANAN

APLIKASI WEB

Vulnerability Assessment terhadap bWAPP (Buggy Web Application)

Aplikasi Target	bWAPP (OWASP)
Lingkungan	Docker, http://localhost:8080
Mata Kuliah	IT Audit
Auditor	Ravi Arnan Irianto
Tanggal	24 Mei 2026

1. Ringkasan Eksekutif (Executive Summary)

Audit keamanan ini dilakukan terhadap aplikasi bWAPP, sebuah aplikasi web yang sengaja dibuat rentan untuk tujuan edukasi, sebagai studi kasus mata kuliah IT Audit. Tujuan audit adalah mengidentifikasi, memverifikasi, dan memetakan kerentanan keamanan aplikasi web terhadap kerangka kerja standar industri OWASP Top 10 2021.

Pengujian dilakukan menggunakan kombinasi pemindaian otomatis (Nikto, OWASP ZAP), eksploitasi terarah (SQLMap), dan pengujian manual. Hasil audit menemukan **4 area temuan utama** dengan tingkat keparahan mulai dari Medium hingga Critical. Dua di antaranya tergolong **Critical** dan memungkinkan penyerang mengambil alih data sensitif tanpa autentikasi.

Temuan paling kritikal adalah kebocoran kredensial melalui file konfigurasi yang terekspos serta kerentanan SQL Injection yang memungkinkan pencurian seluruh isi tabel pengguna, termasuk akun administrator. Aplikasi juga rentan terhadap Cross-Site Scripting dan memiliki sejumlah kesalahan konfigurasi keamanan (security misconfiguration).

Distribusi Tingkat Keparahan

Tingkat Keparahan	Jumlah Temuan
Critical	2
High	1
Medium	1 (kelompok misconfiguration)

2. Ruang Lingkup dan Tujuan (Scope & Objectives)

Target Audit	Aplikasi web bWAPP v2.2 pada http://localhost:8080
Jenis Pengujian	Black-box dan grey-box (dengan kredensial uji bee/bug)
Security Level	Low (security_level=0)
Termasuk dalam Scope	Aplikasi web layer (injection, XSS, info disclosure, misconfiguration, header keamanan)
Di Luar Scope	Audit OS/host, denial-of-service, social engineering, serangan terhadap sistem nyata
Sifat Lingkungan	Lab terisolasi (localhost), aplikasi sengaja dibuat rentan untuk edukasi

3. Metodologi

Audit mengikuti 5 tahap kerja yang umum digunakan dalam vulnerability assessment:

1. **Setup Environment.** Deploy bWAPP via Docker dan verifikasi akses.
2. **Penentuan Scope.** Memilih kategori kerentanan dan menetapkan tingkat kesulitan.
3. **Pengujian.** Pemindaian otomatis, eksploitasi, dan verifikasi manual setiap temuan.
4. **Analisis dan Mapping.** Memetakan temuan ke OWASP Top 10 2021 dan menetapkan severity.
5. **Pelaporan.** Menyusun temuan, bukti, dan rekomendasi remediasi.

Tools yang Digunakan

Tool	Versi	Fungsi
Nikto	2.1.5	Web server scanner (information disclosure, misconfiguration)
SQLMap	1.10.2.6	Deteksi dan eksploitasi SQL Injection otomatis
OWASP ZAP	2.17.0	Dynamic Application Security Testing (DAST)
Manual testing	curl, browser	Verifikasi manual XSS dan kebocoran data

4. Ringkasan Temuan

ID	Temuan	Severity	OWASP 2021	Tool
F-01	Sensitive Data Exposure (kredensial bocor)	Critical	A01, A02, A05	Nikto + manual
F-02	SQL Injection	Critical	A03, A02	SQLMap
F-03	Cross-Site Scripting (Reflected + Stored)	High	A03	Manual
F-04	Security Misconfiguration & Missing Headers	Medium	A05, A01	OWASP ZAP

5. Temuan Terperinci

F-01 Sensitive Data Exposure (CRITICAL)

Deskripsi

File konfigurasi dan file backup yang berisi kredensial dapat diakses publik tanpa autentikasi. Directory indexing yang aktif memperparah kondisi ini dengan menampilkan daftar isi folder sensitif seperti `/passwords/`.

Bukti

Akses langsung ke `http://localhost:8080/config.inc` menampilkan kredensial database:

```
$server = "localhost";
$username = "bwapp";
$password = "bwApped";
$database = "bwAPP";
```

Folder `/passwords/` menampilkan daftar file dan isinya dapat diunduh:

File	Kredensial Terekspos
heroes.xml	6 akun user + password plaintext (neo/trinity, alice/loveZombies, thor/Asgard, dll)
web.config.bak	Connection string ASP.NET: wolverine / Log@N
wp-config.bak	WordPress DB: thor / Asgard

Penilaian Risiko

Severity	Critical (CVSS estimasi 9.1)
OWASP 2021	A01 Broken Access Control, A02 Cryptographic Failures, A05 Security Misconfiguration
Impact	Penyerang memperoleh kredensial database tanpa eksploitasi apa pun, berpotensi full database compromise.

Rekomendasi

- Matikan directory indexing (`Options -Indexes` pada Apache).
- Hapus seluruh file backup (.bak, .inc, .old) dari web root.
- Pindahkan file konfigurasi ke luar document root atau blokir aksesnya.
- Jangan menyimpan password dalam bentuk plaintext, gunakan hashing yang kuat.
- Hapus file installer (install.php) setelah instalasi selesai.

F-02 SQL Injection (CRITICAL)

Deskripsi

Parameter `title` pada modul SQL Injection (GET/Search) tidak melakukan sanitasi input, sehingga input pengguna dieksekusi langsung sebagai bagian dari query SQL.

Bukti

SQLMap mengonfirmasi parameter `title` rentan terhadap 4 teknik injeksi (boolean-based blind, error-based, time-based blind, UNION query) dan berhasil mengekstrak tabel `bwAPP.users`:

```
Database: bwAPP, Table: users [2 entri]
id | login | admin | password (SHA1 unsalted)
1  | A.I.M. | 1      | 6885858486f31043e5839c735d99457f045affd0
2  | bee   | 1      | 6885858486f31043e5839c735d99457f045affd0

Verifikasi: echo -n "bug" | sha1sum => 6885858486f31043e5839c735d99457f045affd0
Password plaintext kedua akun admin berhasil dipulihkan: "bug"
```

Penilaian Risiko

Severity	Critical (CVSS estimasi 9.8)
OWASP 2021	A03 Injection, A02 Cryptographic Failures
Impact	Akses baca penuh ke database, pencurian seluruh kredensial termasuk akun admin. Hash lemah (unsalted SHA1) mudah dipecahkan.

Rekomendasi

- Gunakan prepared statements atau parameterized queries (PDO/MySQLi).
- Terapkan input validation dengan whitelist karakter.
- Ganti penyimpanan password ke bcrypt atau argon2 dengan salt unik.
- Terapkan prinsip least privilege pada akun database aplikasi.

F-03 Cross-Site Scripting / XSS (HIGH)

Deskripsi

Aplikasi tidak melakukan output encoding maupun sanitasi input, sehingga script dari pengguna dieksekusi oleh browser. Ditemukan dua varian: Reflected (GET) dan Stored (Blog).

Bukti

Reflected XSS pada `xss_get.php` (parameter `firstname`), payload dipantulkan tanpa encoding:

Welcome `<script>alert('XSS-bWAPP')</script>` test

Stored XSS pada `xss_stored_1.php`, payload tersimpan permanen di database dan dirender ke setiap pengunjung (telah dibersihkan setelah verifikasi):

`<td><script>alert('Stored-XSS-by-Audit')</script></td>`

Penilaian Risiko

Severity	High (CVSS estimasi: Reflected 6.1, Stored 7.4)
OWASP 2021	A03 Injection (Cross-Site Scripting)
Impact	Pencurian session cookie, session hijacking, defacement, phishing. Diperparah oleh cookie tanpa flag HttpOnly.

Rekomendasi

- Terapkan output encoding sesuai konteks (mis. htmlspecialchars di PHP).
- Lakukan input validation di sisi server.
- Pasang Content Security Policy (CSP).
- Set flag HttpOnly dan Secure pada cookie session.

F-04 Security Misconfiguration & Missing Headers (MEDIUM)

Deskripsi

Pemindaian OWASP ZAP menemukan sejumlah kesalahan konfigurasi keamanan dan header keamanan yang hilang. Total 5 temuan Medium dan 6 temuan Low.

Bukti (Temuan Medium dari ZAP)

Temuan	CWE	OWASP 2021
Absence of Anti-CSRF Tokens	352	A01 Broken Access Control
Application Error Disclosure	550	A05 Security Misconfiguration
Content Security Policy (CSP) Header Not Set	693	A05 Security Misconfiguration
Directory Browsing	548	A05 Security Misconfiguration
Missing Anti-clickjacking Header	1021	A05 Security Misconfiguration

Temuan Low Pendukung

Cookie tanpa HttpOnly, Cookie tanpa SameSite, banner versi server bocor (Apache/2.4.7), header X-Powered-By bocor (PHP/5.5.9, versi End-of-Life), dan X-Content-Type-Options tidak diset.

Rekomendasi

- Tambahkan token Anti-CSRF unik pada setiap form yang mengubah state.
- Set header keamanan: Content-Security-Policy, X-Frame-Options, X-Content-Type-Options: nosniff.
- Set flag HttpOnly, Secure, dan SameSite pada cookie session.
- Gunakan custom error page untuk menyembunyikan detail error.
- Sembunyikan banner versi server (ServerTokens Prod, expose_php Off).
- Update komponen usang (PHP 5.5.9 dan Apache 2.4.7 sudah End-of-Life).

6. Catatan Metodologi: Keterbatasan Automated Scanner

OWASP ZAP melaporkan **0 temuan High**, padahal pengujian manual dan SQLMap membuktikan adanya SQL Injection (Critical) dan Stored XSS (High) pada aplikasi yang sama.

Hal ini terjadi karena ZAP hanya meng-crawl halaman permukaan dan tidak masuk ke modul kerentanan yang berada di balik autentikasi serta tidak ter-link otomatis. Temuan ini menggarisbawahi bahwa automated DAST scanner memiliki blind spot. Audit yang baik harus mengombinasikan pemindaian otomatis dengan pengujian manual dan tools terarah.

Cross-Validation

Beberapa temuan dikonfirmasi oleh dua tool berbeda (Nikto dan ZAP), yang memperkuat validitasnya: Directory Browsing, kebocoran banner versi server, Missing X-Frame-Options, dan Cookie tanpa HttpOnly.

7. Kesimpulan

Aplikasi bWAPP terbukti memiliki kerentanan keamanan yang serius dan beragam, mencakup mayoritas kategori OWASP Top 10 2021. Dua temuan Critical (Sensitive Data Exposure dan SQL Injection) memungkinkan kompromi data secara langsung dan harus menjadi prioritas remediasi tertinggi. Kombinasi metode pengujian (otomatis, eksploitasi, dan manual) terbukti penting karena tidak ada satu tool pun yang menemukan seluruh kerentanan.

Sebagai aplikasi yang sengaja dibuat rentan, bWAPP merupakan media latihan yang efektif untuk memahami proses audit keamanan aplikasi web mulai dari identifikasi, eksploitasi, hingga penyusunan rekomendasi remediasi yang selaras dengan standar industri.

8. Lampiran

Daftar Bukti (Evidence)

File	Keterangan
nikto_scan.pdf	Output pemindaian Nikto (38 temuan)
sqlmap_scan.pdf	Bukti dan analisis SQL Injection
xss_scan.pdf	Bukti XSS Reflected dan Stored
2026-05-24-ZAP-Report-.pdf	Report mentah OWASP ZAP
zap_analysis.pdf	Analisis terstruktur hasil ZAP
sqlmap_output/	Output mentah SQLMap (CSV, log, session)

Referensi

- OWASP Top 10 2021 - <https://owasp.org/Top10/>
- OWASP bWAPP Project - <http://www.itsecgames.com>
- OWASP Cheat Sheet Series - <https://cheatsheetseries.owasp.org>

Laporan ini disusun untuk keperluan akademik mata kuliah IT Audit. Seluruh pengujian dilakukan pada lingkungan lab terisolasi (localhost) terhadap aplikasi yang sengaja dibuat rentan untuk tujuan edukasi. Teknik-teknik dalam laporan ini tidak boleh digunakan terhadap sistem mana pun tanpa izin tertulis.